The 6 Checks Explained

Every check type, what it answers, and the honest limits of each signal.

Exposure-Check-OSINT v1.6.0 · Apache-2.0 · self-hosted · keyless · no AI · github.com/RanaKhan77/Exposure-Check-OSINT

1. Email exposure

Paste any email address. The engine fans out to all supporting sources in parallel (stealer logs, breach analytics, COMB corpus, disposable-domain flags, Gravatar, GitHub public associations) and answers: where is this email exposed, and what does that expose about its owner?

- Breach names, dates and record counts (never other victims' data)
- Infostealer infection counts + machine classifications (no raw cookies/logs)
- Whether the address is disposable/temp (affects how trustworthy it is)
- Public GitHub code/profile associations

v1.1 roadmap: the consent-gated ~120-platform linked-account probe (needs the optional browser-service add-on).

2. Username exposure

One username → which of 150 popular platforms (Maigret + WhatsMyName corpus) have that handle registered, rendered as a platform logo grid. Also Bluesky and Hacker News with profile details. Each found account is a public identity footprint.

3. Phone exposure

An E.164 number (with or without +) → validity, country, line type classification, and COMB leak association. No SMS is ever sent; the checks are database/API lookups only.

4. Password exposure

Your password never leaves your device. The page hashes it with SHA-1 in your browser and sends only the first 5 hex characters to this server (k-anonymity — the same design as Troy Hunt's Pwned Passwords). The server fetches the ~800 hash suffixes for that prefix from HIBP and returns them; your browser matches the full hash locally and shows how many times the password appears in known breach corpora. The full hash — and the password — never reach the server, the database, or any logs.

5. Domain infrastructure

Paste a domain (a bare hostname or a URL — the scheme, path and port are stripped). The domain type answers one question: what does this domain's public infrastructure footprint look like, and how old is it? It is a fraud/trust signal, not a website scan — vulnerability scanning is the Website Vulnerability Scanner's job.

- crt.sh — Certificate Transparency: every subdomain that ever obtained a TLS certificate (counts + first 40 names). A freshly-registered domain with dozens of wildcard subdomains tells a different story than a ten-year-old corporate domain.
- RDAP — registry records: registrar, creation and expiry dates, status flags. Registration age is the classic fraud/trust heuristic: a payment domain registered last week deserves more scrutiny than one registered a decade ago.

Both sources are keyless, read-only and free. Nothing is stored about the check beyond what the privacy contract already allows.

6. IP exposure

An IPv4/IPv6 → open ports and exposed services (Shodan InternetDB, keyless), VPN/proxy/hosting classification (ipapi.is), crawler-network attribution (Bot-CIDR), and DNS blocklist reputation: is the IP listed on Spamhaus ZEN, SpamCop or Barracuda for spam/abuse? (PBL-only policy listings — normal for residential IPs — report severity low; abuse listings medium. Each zone is verified answering via its permanently-listed test address before its verdict counts, so a refused or empty answer degrades to "not assessed", never a fake clean. Requires a normal — non-public — resolver: public resolvers like 8.8.8.8/1.1.1.1 are refused by Spamhaus.) For auditing your own servers and egress IPs — a listing can mean a compromised device or a hijacked router.

What this tool is NOT for

- Not for domains/websites — use the Website Vulnerability Scanner CE (202 modules) for that job.
- Not for checking people you have no authorization to assess. This is a self-audit tool: your own identifiers, or identifiers you are explicitly authorized to assess (your organization's, with permission).

— Not an attack tool. Every lookup is a read-only question to a public API. No credential stuffing, no account takeover, no mass scraping — by construction.